

Project 4: Defining and Performing a Risk Assessment

Cole Dombrowski - MISY 5325

1. Qualitative Risk Assessment Approach

Sabine Coastal Health Network (SCHN) will use a qualitative risk assessment based mainly on Chapters 5, 6, and 8 of *Managing Risk in Information Systems* (3rd ed.) (Gibson & Igonor, 2020), with NIST SP 800-30 Rev. 1 and NIST SP 800-39 providing additional guidance (NIST, 2011; NIST, 2012). SCHN has limited cybersecurity resources and does not have enough historical loss or frequency data to support reliable financial calculations, making a qualitative approach far more defensible and practical (Gibson & Igonor, 2020). The assessment relies on SCHN's operating conditions, professional judgment, likelihood, and potential impact to evaluate and rank each risk (Gibson & Igonor, 2020; NIST, 2012).

The assessment focuses on SCHN's critical healthcare activities and systems within the assessment boundary, including patient care, electronic health records (EHRs), connected medical devices, network access, and third-party systems.

2. Likelihood and Impact Criteria

Likelihood

- **Very Low:** The event is unusual and there is little evidence suggesting it will occur.
- **Low:** The event is possible, but current conditions make it relatively unlikely.
- **Moderate:** The event is reasonably possible given SCHN's exposure and vulnerabilities.
- **High:** SCHN has significant exposure or vulnerabilities that make the event likely.
- **Very High:** Conditions strongly indicate that the event is highly likely or could reasonably be expected to occur.

Impact

- **Very Low:** Minimal disruption with little effect on SCHN's operations, patients, finances, or information.
- **Low:** Limited consequences that can be managed through normal procedures.
- **Moderate:** Noticeable operational, financial, compliance, patient-care, or reputational consequences.
- **High:** Serious disruption, significant regulatory or financial exposure, information loss, or interruption of important healthcare services.
- **Very High:** Severe consequences affecting patient safety, critical healthcare operations, major regulatory obligations, or SCHN's ability to provide essential services.

Qualitative Risk Matrix: See Table 1.

3. Selected Risks

Based on Projects 2 and 3, six significant risks were selected for assessment by analyzing threat/vulnerability pairs and their potential impact on core assets (Gibson & Ignor, 2020). The six risks selected for assessment are Ransomware, Credential Compromise, Medical IoT Disruption, Vendor ePHI Exfiltration, Insider Misuse, and Physical Endpoint Theft.

4. Qualitative Risk Assessment Table: See Table 2.

5. Analysis of the Three Highest-Priority Risks

R1 – Ransomware

Risk and Organizational Importance: A ransomware attack could make EHR and clinical systems unavailable, disrupting medication management, diagnostics, admissions, and patient care (Gibson & Igonor, 2020).

Likelihood – High: SCHN’s system vulnerabilities and limited cybersecurity resources increase its exposure to ransomware.

Impact – Very High: A widespread EHR outage could disrupt care across facilities, delay treatment, and create financial and regulatory consequences (NIST, 2012).

Existing Controls/Conditions: SCHN has perimeter firewalls and periodic backups, but patching, network segmentation, and recovery capabilities remain concerns.

Overall Risk Level – Critical: High likelihood combined with very high impact results in a Critical risk level (Gibson & Igonor, 2020).

Management Priority – 1: R1 receives the highest priority because it could simultaneously disrupt clinical operations and patient care.

R2 – Credential Compromise

Risk and Organizational Importance: Stolen credentials could provide unauthorized access to systems and protected health information (Gibson & Igonor, 2020).

Likelihood – High: SCHN’s external communications and lack of universal MFA increase exposure to phishing and social engineering.

Impact – High: A successful compromise could expose PHI, disrupt operations, and create privacy and regulatory consequences (Gibson & Igonor, 2020).

Existing Controls/Conditions: Email filtering and security awareness training provide some protection, but MFA coverage remains incomplete.

Overall Risk Level – High: High likelihood combined with high impact results in a High risk level (Gibson & Igonor, 2020).

Management Priority – 2: R2 is prioritized because compromised credentials could provide an initial foothold for further attacks, including ransomware.

R3 – Medical IoT Disruption

Risk and Organizational Importance: Compromise of connected medical devices could interrupt monitoring or interfere with treatment (Gibson & Igonor, 2020).

Likelihood – Moderate: Medical devices may have limited external exposure, but legacy systems and limited segmentation could allow access.

Impact – Very High: Device disruption could interfere with treatment and create patient-safety consequences (NIST, 2012).

Existing Controls/Conditions: Clinical engineering maintenance and firewalls provide protection, while limited segmentation remains a concern.

Overall Risk Level – High: Moderate likelihood combined with very high impact results in a High risk level (Gibson & Igonor, 2020).

Management Priority – 3: R3 remains a top priority due to its potential effect on patient safety.

6. Management Prioritization and Tradeoff Decision

SCHN has limited cybersecurity personnel and financial resources and cannot address all six risks simultaneously (Gibson & Igonor, 2020). Based on the qualitative assessment, R1, R2, and R3 should move forward into Project 5. These risks receive the greatest immediate attention because they combine significant likelihood or severe impact with potential effects on critical healthcare operations and patient safety (Gibson & Igonor, 2020; NIST, 2012).

R4, R5, and R6 receive lower immediate priority because their assessed combination of likelihood and impact is lower, or because their primary consequences are more limited in scope. By delaying these risks, SCHN accepts the possibility of third-party data exposure, insider misuse of patient records, and physical loss of mobile devices (Gibson & Igonor, 2020). These risks should continue to be monitored and reassessed if organizational conditions change.

7. Connection to Projects 1–3

This assessment builds on Projects 1–3 by using the assets and business activities from Project 2 and the threats, vulnerabilities, and exploits from Project 3. Project 4 adds likelihood, impact, risk level, and management priority to those findings (Gibson & Igonor, 2020; NIST, 2012).

One conclusion was reconsidered: physical loss or theft of mobile endpoints was previously identified as a concern because of its potential effect on protected health information. After comparing its likelihood and impact with the other risks, R6 was assigned a lower management priority.

Table 1. Qualitative Risk Matrix

Likelihood	Very Low Impact	Low Impact	Moderate Impact	High Impact	Very High Impact
Very Low	Low	Low	Low	Moderate	Moderate
Low	Low	Low	Moderate	Moderate	High
Moderate	Low	Moderate	Moderate	High	High
High	Moderate	Moderate	High	High	Critical
Very High	Moderate	High	High	Critical	Critical

Table 2. Qualitative Risk Assessment

Risk	Asset / Business Activity	Threat	Vulnerability	Existing Control or Condition	Likelihood	Impact	Risk Level	Priority
R1	EHR and clinical databases	Ransomware	Unpatched systems and limited segmentation	Firewalls and periodic backups	High	Very High	Critical	1
R2	Remote access and email	Phishing / social engineering	Missing universal MFA and workforce susceptibility	Email filtering and security training	High	High	High	2
R3	Medical IoT devices	Malicious network actors	Legacy firmware and limited segmentation	Clinical engineering maintenance and firewalls	Moderate	Very High	High	3
R4	Vendor interfaces and portals	Vendor compromise	Over-permissive third-party access	Business Associate Agreements and user accounts	Moderate	High	High	4
R5	Patient records	Insider misuse	Excessive permissions and limited monitoring	Unique accounts and stored audit logs	Moderate	Moderate	Moderate	5
R6	Clinic laptops and tablets	Physical theft	Inconsistent device protections	Physical locks and password controls	Low	Moderate	Moderate	6

References

- Gibson, D., & Igonor, A. (2020). *Managing risk in information systems* (3rd ed.). Jones & Bartlett Learning.
- National Institute of Standards and Technology. (2011). *Managing information security risk: Organization, mission, and information system view* (NIST Special Publication 800-39). U.S. Department of Commerce.
- National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30, Revision 1). U.S. Department of Commerce.